

NRB CRG 2023 Comprehensive Cyber Resilience Policy

Nepal Rastra Bank Cyber Resilience Guideline 2023 – Full Compliance Document

Version 1.0 | Classification: CONFIDENTIAL | All Sections Covered

This policy document establishes the comprehensive cyber resilience framework in full alignment with the Nepal Rastra Bank (NRB) Cyber Resilience Guideline (CRG) 2023. It covers all 190 requirements related to governance, identification, protection, detection, response, recovery, testing, situational awareness, information sharing, and learning and evolution as prescribed by the NRB CRG 2023 for Licensed Institutions (LIs).

I. Cyber Resilience Governance and Strategy

1.1 Steering Committee Establishment The Licensed Institution (LI) shall establish an internal cross-disciplinary steering committee comprised of senior management and appropriate staff (employees and/or contractors) from multiple business units including business, finance, risk management, internal audit, operations, cybersecurity, information technology (IT), communications, legal, and human resources. This steering committee shall collectively develop a cyber resilience strategy and framework providing multiple views and perspectives to ensure the strategy is holistic and focuses on all elements related to people, processes, and technology.

1.2 Cyber Resilience Strategy The LI shall ensure the following aspects are addressed in the strategy: the LI's cyber resilience vision and mission; identification of critical operations assets functions and roles; defined cyber resilience objectives and risk tolerance; roadmaps for achieving the target maturity level from the current state; alignment with enterprise operational risk management framework; and communication and coordination mechanisms with relevant parties.

1.3 Board Approval and Oversight The board of the LI shall approve the cyber resilience plan and ensure it is reevaluated and updated on a regular basis in accordance with the LI's threat landscape. The board shall establish the LI's cyber risk tolerance and cyber resilience strategy, specify roles and duties for dealing with cyber risk, and endorse the cyber resilience framework.

1.4 Cyber Resilience Framework The LI shall have a cyber resilience framework that clearly sets out how it determines its cyber resilience objectives and risk tolerance, as well as how it effectively identifies, mitigates, and manages its cyber risks to support its objectives. The framework shall be approved by the LI board to ensure consistency with the organization's developed cyber resilience strategy.

1.5 Framework Review and Update The LI's cyber resilience framework shall be regularly reviewed and updated. When there are changes to the LI's cyber resilience strategy or objectives, the cyber resilience framework containing all policies, technological standards, processes, and controls shall be reviewed and updated. The LI shall create a review process that considers factors including: current and evolving cyberthreats such as those associated with the supply chain, use of cloud services, social media, mobile applications, and internet of things; results of testing programs; and audits carried out by independent compliance programs.

1.6 Communication and Coordination Mechanism The LI's cyber resilience framework shall include requirements for a timely communication and coordination mechanism so that the LI can work with the relevant parties to successfully respond to and recover from cyberattacks. The framework shall be aligned with its enterprise operational risk management framework and enterprise architecture.

1.7 Ecosystem Risk Consideration The LI's cyber resilience framework shall consider the cyber risks the LI faces from and poses to its participants, other LIs, suppliers, vendor goods, and service providers, which are referred to together as the LI's ecosystem. The framework shall employ leading industry-level standards, guidelines, or recommendations such as the ISO/IEC 27000 series as benchmarks.

1.8 Roles, Responsibilities, and Accountability The LI's cyber resilience framework shall clearly define roles and responsibilities including accountability for decision making within the institution for identifying, mitigating, and managing risks. The framework shall systematically incorporate requirements related to governance, identification, protection, detection, reaction and recovery, testing, situational awareness, and learning and evolution.

1.9 Independent Compliance Programs and Audits Through independent compliance programs and audits carried out by qualified staff, the LI shall periodically evaluate and measure the sufficiency and effectiveness of its cyber resilience framework including all security controls and adherence to it. The LI shall apply relevant metrics, maturity models, and results of its testing programs. The LI shall routinely order an external audit.

1.10 Monitoring Capability Maturity The LI shall monitor its development of cyber resilience capabilities on a continuous basis as it progresses from a current state to a defined future state which is a target maturity level. The LI shall have a strategy for reaching its target level that outlines roadmaps for how it will be resourced and delivered.

II. Board and Senior Management Responsibilities

2.1 Board Cyber Risk Governance The board of the LI is ultimately responsible for making sure that cyber risk is properly managed. The board shall establish the LI's cyber risk tolerance and cyber resilience strategy, specify roles and duties for dealing with cyber risk, and endorse the cyber resilience framework. The board and senior management shall establish a process to ensure that cyber risk is identified and addressed on an ongoing basis. All business units shall be involved in the decision to accept, mitigate, or avoid these risks, consistent with the LI's risk management framework.

2.2 Risk Metrics and Board Reporting The LI shall develop relevant risk metrics, identifying trends and patterns, to be used by senior management and the board to make risk-informed decisions and to demonstrate progress in the implementation of its cyber resilience framework. The board and senior management shall ensure that the LI's cyber risks and management of those risks are regularly evaluated during board meetings.

2.3 Senior Management Oversight Senior management shall closely oversee the LI's implementation of the cyber resilience framework and the policies, technical standards, procedures, and controls that support it. This oversight includes: allocating resources and setting priorities for cyber resilience deliverables based on findings of cyber resilience assessments, key performance indicators, key risk indicators, overall business goals, and progress toward target maturity; periodically assessing the LI's cyber maturity through self-assessments of cyber resilience; assessing the self-evaluation and lessons learned from test results, and taking appropriate decisions to improve the effectiveness of cyber activities.

2.4 Employee Awareness, Responsibility, and Training Senior management shall make sure that every employee is aware of their responsibility for reducing cyber risk and has access to the necessary training. For high-risk employees such as senior management, system administrators, software developers, and critical system operators, the board and senior management shall create succession plans as necessary. Senior management shall help plan and participate in industry-wide drills that test and improve the cyber resilience of the LI's ecosystem.

2.5 Cyber Resilience Culture The board and senior management shall cultivate a strong level of awareness of and commitment to cyber resilience, fostering a culture where workers at all levels are aware they have important responsibilities for ensuring the LI's cyber resilience. The senior management shall make sure that everyone within the institution has a better understanding of cyber risk. Training curriculum shall be revised frequently to reflect the evolving threat landscape of the ecosystem.

2.6 Cybersecurity Policy for Staff and Contractors The LI shall create policies outlining the repercussions for staff members and contractors who do not abide by cybersecurity regulations. The regulations shall be precise and appropriate for the risk and situational context involved. The senior management shall ensure that situational awareness materials are made available to relevant employees when prompted by highly visible cyber incidents, changes to the threat landscape, and the impacts of these threats to the LI.

2.7 Skills, Expertise, and Board Competency The board and senior management of the LI shall be comprised of individuals who have the right mix of expertise, knowledge, and experience to comprehend and control the cyber risks that the LI faces. The board shall be well-informed to challenge suggestions and decisions made by designated senior management. The LI shall appoint at least one board member with cybersecurity expertise.

2.8 Chief Information Security Officer (CISO) A senior executive such as a Chief Information Security Officer responsible for carrying out the organization's cyber resilience architecture shall be appointed by the board and senior management. The LI shall ensure that this senior executive has sufficient authority and access to required resources including people and technology; access to directly report to the board; operational independence from other IT operations; and the necessary skills and knowledge to successfully plan and execute the LI's cyber resilience initiatives.

2.9 Privileged Access Training The senior management of the LI shall ensure that employees and contractors with privileged accounts who have access to sensitive assets and information receive additional cyber resilience training according to the criticality to the business.

III. Identification - Asset Inventory and Risk Assessment

3.1 Critical Functions and Key Roles Documentation The LI shall identify and document all its critical functions, key roles, and processes that support those functions, and update this information on a regular basis. The LI shall identify and document all processes dependent on third-party service providers and identify its interconnections, and update this information on a regular basis.

3.2 Business Impact Analysis The LI shall perform a business impact analysis to quantify the impact of disruptions on its critical operations. The LI shall have an enterprise risk management framework to identify risks and conduct risk assessments on a regular basis.

3.3 Critical Function Classification The LI shall classify its functions and business processes according to their criticality; this information shall be used for prioritizing its protective, detective, response, and recovery measures. The LI shall create and maintain a simplified network map of network resources with an associated plan addressing IPs which locate routing and security devices and servers supporting the LI's critical functions, which identify links with the outside world.

3.4 Risk Assessments for New Technologies The LI shall compulsorily conduct the needed risk assessments before deploying new and updated technologies, products, services, and connections to identify potential threats and vulnerabilities.

3.5 Information Asset Identification and Inventory The LI shall identify the information assets (including assets under the direct ownership of the LI and assets that the LI relies on for its critical business operations but are not owned by the LI itself) supporting its business processes. The LI shall: establish a standard for categorizing information and information systems in accordance with the LI's security policy, including its level of concern for availability, confidentiality, and integrity; identify and maintain an up-to-date and centrally managed inventory of its information assets and system configurations; and develop and maintain an up-to-date network diagram that includes network resources including IP addresses and subnets, connected components, and internal and external service links including interconnections with other stakeholders, internet-facing services, cloud services, and any other third-party systems.

3.6 Cyber Security Risk Assessment and Risk Register The LI shall adopt and apply a cyber security risk assessment process and maintain a risk register to document and monitor risks. The criteria for conducting and/or updating assessments shall be specified in the risk assessment process, such as system development and renewal, emerging threats, and recognized vulnerabilities inside the LI's systems or infrastructure. The risk register shall identify and categorize risks according to their criticality.

3.7 Risk Assessment Documentation and Risk Register Update The LI shall conduct and document risk assessments of its information assets in accordance with its cyber security risk assessment process. The LI shall consult and update its risk register based on the outcome or progress of risk assessment results. These results shall drive the selection and implementation of security controls, prioritizing them according to the risks faced by the LI.

3.8 Central Account and Permissions Repository The LI shall maintain a central repository of individual and system accounts and permissions. The repository shall: identify access rights to information assets; contain applicable information that will help the LI to identify any anomalous activities; and be protected from unauthorized access and modification.

3.9 Integration with Acquisition and Change Management The LI shall integrate identification efforts with other relevant processes such as acquisition and change management so that it could facilitate a regular review of the LI's assets and permissions.

3.10 Ecosystem Cyber Risk Identification The LI shall identify the cyber risks that it bears from or poses to entities in its ecosystem and coordinate with relevant entities as appropriate. This may involve identifying vulnerabilities and threats that they share and taking appropriate action to mitigate those risks collectively.

3.11 Threat Vectors and Interconnection Risk Analysis The LI shall take into account a wide range of potential threat vectors and risks that could lead to a potential breach of the LI's essential business functions to identify and assess the risks from participants' interconnections. This process shall include determining the likelihood of a potential threat occurring, assessing the impact in the event the threat is realized, and analyzing the risk to the LI. The LI shall also assess potential risks to the LI's ecosystem that could arise from participant interconnections.

3.12 Third-Party Service Provider Risk Evaluation The LI must know the services and business operations of the third-party service provider, including details of the services provided and the manner in which those services will be delivered, in order to identify and evaluate the risks posed by interconnections. The LI may rely on various sources to gather this information including publicly available data, self-assessments, and third-party assessments.

IV. Protection - Preventive Security Controls

4.1 Protective Controls Aligned to Standards The LI shall implement appropriate protective controls that are in line with leading-practice cyber resilience standards such as ISO standards to minimize the likelihood and impact of a successful cyber-attack on identified critical business functions, information assets, and data. The LI shall implement these controls in accordance with the risk analysis completed during the identification phase based on the identification of its critical operations, key roles, procedures, information assets, third-party service providers, and interconnections.

4.2 Proportionate Controls and Defense-in-Depth Protective controls shall be proportionate to the LI's threat landscape and systemic role in the financial system, and consistent with its risk tolerance. The LI shall implement multiple independent security controls necessary for protecting its systems, processes, and data at the earliest possible stage. The LI shall apply a defense-in-depth strategy implementing multiple independent security controls so that if one control fails or a vulnerability is exploited, alternative controls will protect targeted assets and processes.

4.3 Resilience by Design in System Development The LI shall take into account cyber resilience from the very beginning of the design and development of the system all the way through its life cycle. This reduces software and hardware vulnerabilities and guarantees that proper security measures are built into systems and processes from the beginning. If the system or any of its components are acquired from or operated by a third-party supplier, the LI shall obtain assurance that the vendor has applied the appropriate security controls. The LI shall: implement a system development methodology that incorporates the resilience by design approach; establish and communicate principles for engineering secure systems; capture security requirements alongside system and process requirements; separate physically and/or logically the development, testing, and production environments; assess the effectiveness of security controls regularly; apply a defense-in-depth strategy; thoroughly examine and test business-critical software systems and networks; limit attack surfaces by disabling unnecessary or unused functionality and services; ensure that change control processes and procedures regulate changes to systems during the development life cycle.

4.4 Data and Information Protection To ensure the confidentiality, integrity, and availability (CIA) of the LI's data and information at rest and in use, the LI shall implement strong data and information protection controls. These include but are not limited to: protection against malware through scanning, blocking, and quarantine at network entry and exit points, email gateways, servers, and end systems; protection against phishing attacks through detection and mitigation; integrity verification tools to detect unauthorized changes to critical files from internal and external sources; data encryption commensurate with the LI's criticality, sensitivity, and risk assessment processes; encryption in line with recognized standards covering algorithm, key length, key generation, and key management; physical protection of equipment used to generate, store, and archive keys; regular vulnerability assessment of its production environment; validation of all information inputs in applications particularly for web-facing applications; prevention of unauthorized disclosure modification removal or destruction of information stored on media; secure disposal of media when no longer required using defined formal procedures; and when transporting media, protection of information stored on the media against unauthorized access, misuse, or corruption.

4.5 Communications and Network Security The LI shall implement strong communications and network security controls including but not limited to: implementation of secure network protocols and encryption to protect the confidentiality and integrity of information exchanged within its network and beyond including remote connections and third-party interconnections; a broad range of technologies and tools to detect and block actual and attempted attacks or intrusions including those from authorized third-party connections such as intrusion detection or prevention systems and end-point security solutions; controls that manage or prevent unauthorized or unregistered devices from connecting to the LI's logical internal network; protection of critical information systems against denial-of-service attacks including massive distributed denial of service (DDoS) attacks; regular scanning of legacy technologies to identify potential vulnerabilities; and assurance that protection extends to the LI's entire attack surface.

4.6 Configuration and Change Management Policy The LI shall have a configuration and change management policy, process, and procedures in place based on well-established and industry-recognized standards and best practices. The LI shall configure ICT systems and devices with security settings consistent with the level of protection defined in its security policy including: establishment and documentation of baseline system security configuration standards; application of industry-level standards when planning, designing, building, and maintaining systems; regular enforcement checks to ensure non-compliance is promptly rectified; a formal risk-based process for handling and approving exceptions; and periodic review of baseline configuration standards.

4.7 Anomaly Detection and Baseline Monitoring The LI's protective controls shall enable monitoring and detection of anomalous activity. The LI shall: define and document the baseline profile of system activities proportionate to risk to help detect deviation from the baseline including anomalous activities and events; develop the appropriate capabilities including people, processes, and technologies to monitor and detect anomalous activities and events by setting appropriate criteria, parameters, and triggers to enable alerts including adding functionality in systems or applications to detect unusual transactions and behaviors.

4.8 Containment and Network Segmentation Where feasible and practical, the LI shall develop the necessary capabilities to block suspected activity at the application and/or network level to contain anomalous activity. To segregate systems and data of varying criticality, the LI shall: establish a secure boundary protecting its network infrastructure using tools such as routers, firewalls, Intrusion Prevention Systems (IPS) or Intrusion Detection Systems (IDS), Virtual Private Networks (VPN), Demilitarized Zones (DMZ), or proxies; manage and control networks to protect information in systems and applications; use a separate and dedicated logical network for information system administration; design its network connection infrastructure so connections can be segmented or severed instantaneously to prevent contagion and lateral movement; implement automated mechanisms that can isolate affected information assets in case of an adverse event.

4.9 Ecosystem and Participant Protection Requirements The LI shall implement protective measures to mitigate risks arising from the entities in its ecosystem. If necessary, the LI shall specify participation requirements to ensure it can meet its cyber resilience objectives. The LI shall impose rules including but not limited to: connectivity restrictions; access control and privileged account management; identification and authentication management; confidentiality and integrity protection via encryption; vulnerability and patch management; detection and response management; and security awareness and training.

4.10 Third-Party Vendor Cyber Resilience The LI shall obtain assurance from its participants that they meet the LI's cyber resilience requirements through participant self-attestations or external third-party certifications. The LI shall request confirmation that its third-party vendors and service providers including ICT suppliers meet its requirements for cyber resilience. Contracts shall cover: validation of security capabilities; information security requirements for mitigating risks associated with third-party access to the LI's information assets; confidentiality and non-disclosure requirements; information security risks associated with information and communications technology services and product supply chains; and notification of changes to service levels or security functionality.

4.11 Third-Party Risk Profile Update and Insider Threat Monitoring The LI shall update its risk profile component related to third parties as appropriate upon notification of changes to third-party service levels or security functionality. The LI shall implement measures to monitor anomalous behavior by users of its systems and use data loss identification and prevention techniques to prevent removal of sensitive and confidential data from its network.

4.12 Background Checks and Employment Lifecycle Security In order to reduce insider threats, the LI shall screen and background-check new employees. Similar checks shall be performed on every employee periodically throughout their employment commensurate with access to critical systems. The LI shall incorporate cybersecurity at every stage of the employment life cycle outlining security-related steps that must be taken during each employee's onboarding, ongoing management, and termination. This includes: conducting pre-employment background security checks; ensuring current employees and contractors comply with established policies procedures and controls; making sure all access rights related to an employee's previous position not required for their new responsibilities are promptly revoked; and putting in place processes to promptly revoke all access privileges from departing or unrelated employees.

4.13 Physical Access Controls and Identity Verification All employees, contractors, and outside parties shall be required to wear an identity card issued by the institution. Security personnel shall be alerted immediately if they encounter anyone not wearing the institution-issued identity card. Access to secure areas or confidential information

processing facilities including for outside support staff shall only be granted when necessary, authorized, and monitored.

4.14 Logical Access Control and Authentication The LI shall ensure: prior to account creation and authorization each user's identity has been confirmed; all internal and external users have been uniquely identified and authenticated so actions and activities can be attributed to individual users; the authentication mechanism such as passwords, tokens, biometrics, public key infrastructure certificates, or key cards shall be set per the criticality of the information system; critical systems processes and roles shall all require multi-factor authentication wherever supported with password complexity requirements enforced; a formal access control model such as role-based access control enforces an access control policy; the principle of separation of duties has been applied to application processes and/or transactions that may be at risk of fraud or misuse; and procedures have been established to control the creation, modification, and deletion of user accounts and access rights with proper authorization and recording for periodic review.

4.15 Physical Security of Information Processing Facilities The LI shall ensure: information processing facilities and areas containing sensitive and critical information are protected by defined security perimeters; access to secure areas is restricted to authorized personnel only by means of proper entry controls; critical computing equipment is situated and safeguarded with water damage protection, fire suppression systems, temperature and humidity controls, and emergency power and lighting; wireless access points, power cables, and telecommunications cabling related to critical systems are protected from tampering and damage; and equipment is properly maintained to ensure its continuous availability and integrity.

4.16 Staff Security Compliance and Cybersecurity Training Information security shall be complied with by all employees including senior management and board members and contractors in accordance with the LI's established cyber resilience policies, technical standards, and procedures. The LI shall: make sure all employees receive training to develop and maintain the necessary awareness and skills for identifying and addressing cyber-related risks such as spear phishing training; train staff on how to report unusual activity and incidents such as phishing attempts; ensure staff members are well-versed in cyber risks they may encounter while performing their duties; include a cybersecurity awareness course in the onboarding program for new employees; train relevant staff before go-live of new systems or applications; ensure staff are familiar with standard operating procedures; and assess the training's effectiveness to see if the awareness and training have a positive impact on behavior.

4.17 Specialized Training for High-Risk Groups The LI shall identify staff members and subcontractors in high-risk groups such as those with privileged system access or in delicate business roles, and give them specialized information security training.

V. Detection - Monitoring and Event Management

5.1 Continuous Monitoring Against Baseline The LI shall implement continuous monitoring against the baseline profile of system activities. The LI shall: develop and implement automated detection systems such as a security information and event management system that correlate all network and system alerts with unusual activity across all business units; have capabilities to monitor user activity exceptions and cybersecurity events and network connections external service providers devices and software; continuously monitor and inspect network traffic including remote connections and endpoint configuration and activity to identify potential vulnerabilities or anomalous events in a timely manner; and compare the network traffic with the expected traffic.

5.2 Behavioral Analytics and Threat Detection The LI shall: collect, monitor, and analyze patterns and behavior such as network use patterns, work hours, and known devices to identify anomalous activities and evaluate implementation of emerging solutions such as data analytics, machine learning, and artificial intelligence; ensure its detection capabilities are informed by threat and vulnerability information collected from different sources and providers; implement an advanced threat detection capability to recognize known threats, improve the chance of identifying zero-day vulnerabilities and threats using recently discovered attack chains, methods, and techniques; ensure it understands and has anticipated use cases of threats of misuse by insiders and trusted third parties and has developed capabilities to detect these threats within applications, databases, systems, and networks; have processes in place to monitor activities not in accordance with its security policy.

5.3 Multi-Layered Detection Controls The LI shall use detection capabilities by implementing multi-layered detection controls that cover people, processes, and technology with each layer serving as a safety net for the preceding layer. The LI shall constantly investigate new technologies and techniques to prevent lateral movement. The LI shall ensure its detection capabilities are periodically reviewed, tested, and updated appropriately. The monitoring and detection capabilities of the LI shall send notifications to the concerned staff.

5.4 Forensic Logging and Evidence Integrity To facilitate forensic investigation, the LI shall ensure: anomalies and events detected are recorded in event or system logs; there is enough storage capacity for the necessary logs; the logs' content includes the necessary information to support investigation such as event type, time, user address; and audit data and tools are protected against unauthorized access, modification, or deletion. The LI shall ensure logs are backed up in a secure location and that controls are in place to mitigate the risk of alteration. The LI shall implement a time synchronization capability to ensure correlated logs have consistent times.

5.5 Security Analytics and Centralized Event Correlation The LI shall have a process to collect, centralize, and correlate event information including anomalous activity from multiple sources and log analysis to continuously monitor the IT environment such as databases, servers, and endpoints. This capability could be achieved through a security operations center (SOC), network operations center, or equivalent.

VI. Incident Response, Resumption, and Recovery

6.1 Comprehensive Cyber Incident Response Capability The LI shall have a comprehensive cyber incident response capability that includes detection and analysis as well as containment, elimination, and recovery; and post-incident activity. This capability could include direct cooperative or contractual agreements with incident response organizations or providers to help with mitigation efforts as quickly as possible.

6.2 Investigation, Root Cause Analysis, and Evidence The LI shall have the resources, policies, and procedures in place to conduct a thorough investigation of a cyber-attack including root cause analysis. When a successful or attempted cyber-attack is detected and confirmed, the LI shall deploy its investigative capability to determine the nature and extent of the attack as well as the damage inflicted.

6.3 Containment Actions During Investigation While the investigation is ongoing, the LI shall take immediate action to contain the cyber-attack or attempted cyber-attack to prevent further damage and begin efforts to resume operations based on its response planning.

6.4 Escalation Procedures for Cyber Incidents Based on the potential impact and criticality of the risk, the LI shall establish criteria and procedures for escalating cyber incidents to the board and senior management. The LI shall also have procedures to escalate investigations to law enforcement agencies as needed. The LI shall ensure its incident response team has the requisite skills and training to address cyber incidents. The LI shall train its employees so they understand their roles and responsibilities in handling digital evidence and ensuring it is not compromised and remains valid in accordance with the requirements of the local jurisdiction.

6.5 Resumption Within Two Hours (RTO) Objectives for resuming operations shall be planned for and tested. The LI shall design and test its systems and processes to enable: the safe resumption of critical operations within two hours of a disruption; and completion of settlement by the end of the day of the disruption even in the case of extreme but plausible scenarios. Planning to enable resumption within two hours of a cyber incident requires a detailed and comprehensive understanding of the LI's functions and processes. The LI shall involve both technical and business teams to carefully plan for risks specific to the LI's design, critical functions, and processes.

6.6 Contingency Planning for Extended Disruptions While the LI shall aim to resume critical operations safely within two hours, it shall also prepare for scenarios in which this objective is not achieved. The LI shall analyze critical functions, transactions, and interdependencies to prioritize resumption and recovery actions. The LI should also plan for situations in which critical people, processes, or systems may be unavailable for significant periods by reverting where feasible safe and practicable to manual processing. The LI shall devise a backup plan including: addressing how the LI could achieve its recovery objectives and restoration priorities; defining roles and responsibilities; and setting out options for rerouting or substituting critical functions and services affected for an extended period.

6.7 Comprehensive Incident Response, Resumption, and Recovery Plans To manage cybersecurity incidents, the LI shall develop comprehensive cyber incident response, resumption, and recovery plans which can be part of the Business Continuity Plan or as a separate document. These plans shall aim to limit damage and prioritize resumption and recovery actions that facilitate critical transaction processing while reducing recovery time and costs. The response plan shall specify actions to be taken as soon as a cyber incident is detected; the resumption plan shall include actions to restore and resume the LI's critical business operations possibly in a reduced capacity as soon as it is safe and practicable to do so with two hours as the target objective; and the recovery plan shall outline the steps for the LI to safely return to a fully functional normal operating state.

6.8 Plan Policies, Procedures, Roles, and Responsibilities Response, resumption, and recovery plans shall define policies and procedures as well as roles and responsibilities for escalating, responding to, and recovering from cyber incidents. In developing its plans, the LI shall: include a range of extreme but plausible scenarios to assess the potential impact on the LI and the broader ecosystem; and consult and coordinate with all relevant business units and external stakeholders.

6.9 Regular Plan Updates, Testing, and Stakeholder Coordination The LI shall regularly update its plans including: reviewing its range of scenarios; conducting business impact assessments in line with the evolving threat landscape; and incorporating lessons learned from previous cyber incidents including root cause analysis findings. The LI shall test its response, resumption, and recovery plans against a variety of scenarios on a regular basis. The LI shall consult with relevant external stakeholders within the ecosystem to improve its plans. The LI shall put in place processes to improve its plans on a continuous basis considering cyber threat intelligence sources and information shared within its ecosystem.

6.10 Integration with Crisis Management and Business Continuity The LI's cyber incident response, resumption, and recovery processes shall be closely integrated with crisis management, business continuity, and disaster recovery planning and operations. System and process design and controls for critical function and operation shall support incident response activities as much as possible. The LI shall design systems and processes to minimize the impact of any cyber incident, to resume critical operations within two hours of a disruption, to complete settlement by the end of the day, and to maintain transaction integrity. When designing its systems and processes the LI shall consider a variety of scenarios and potential response actions.

6.11 Data Integrity and Recovery Point Objectives The LI shall define and identify data critical for the resumption of services which shall be backed up, including not only transactional data but also other critical data such as source code and business reference data. The LI shall have plans in place to quickly determine the status of all transactions and member positions in the event of a disruption, backed up by recovery point objectives. The LI shall design and test its systems and processes to ensure recovery of accurate data following a breach. Recovery point objectives to support data integrity efforts shall be consistent with the LI's resumption time objective for critical operations. Recovery point objectives and data recovery options shall be established in close collaboration with the business and IT functions.

6.12 Backup Solutions, Redundancy, and Data Recovery The backup solutions provided by the LI shall be configured to align with the frequency and volume of transactions. The backup and recovery methods and strategies shall be integrated into the LI's system infrastructure at the development and acquisition phase. The LI shall back up its information system by maintaining a redundant secondary system not located in the same place as the primary system that can be activated without information being lost or operations disrupted. Data recovery measures shall be included in the LI's cyber resilience framework including: implementing database record recovery mechanisms such as record rollback and logging; conducting more frequent independent reconciliation of participants' positions; and keeping a copy of all received and processed data and related information. Backups shall be protected both at rest and in transit to ensure data confidentiality, integrity, and availability, and shall be tested on a regular basis to ensure availability and integrity.

6.13 Data-Sharing Agreements and Information Sharing The LI shall have a data-sharing agreement in place with third parties and participants as appropriate to facilitate obtaining uncorrupted data for resuming business operations in a timely manner. The LI shall review information-sharing rules, agreements, and protocols on a regular basis to control the publication and distribution of information and prevent disclosure of sensitive information.

6.14 Contagion Management and Ecosystem Coordination In the event of a large-scale cyber incident, the LI shall develop policies and procedures outlining how it will collaborate with relevant interconnected entities to resume

operations with the first priority being its critical functions and services as soon as it is safe and practicable without putting the broader sector or the financial system at risk.

6.15 Crisis Communication Plan The LI shall develop a communication plan and procedures for communicating with participants, linked FMIs, authorities, and others such as service providers and media where relevant. The LI's communication plan shall be informed by scenario-based planning and analysis as well as previous experience. The incident response plan shall identify internal and external stakeholders who must be notified, decision-making responsibilities and authorities, and information that must be shared and reported, as well as when this should take place.

6.16 Regulatory Reporting and Responsible Disclosure Any cyber incident that could be material or systemic shall be immediately reported to relevant oversight and regulatory authorities by the LI. The LI shall follow the requirements of NRB's related directive/guideline when reporting cyber incidents to the NRB. When there are indications of criminal intent such as fraud or extortion, the LI shall have procedures in place to escalate investigations to law enforcement agencies. The LI shall have a policy and procedures in place to allow for the responsible disclosure of potential vulnerabilities and risks within its ecosystem. The LI shall prioritize disclosures that will assist participants and other stakeholders in responding quickly and mitigating their own risk.

6.17 Forensic Readiness Capability The LI shall develop the capability to support or assist in forensic investigations. This capability shall include the ability to design protective and detective controls to aid in the investigation process. The LI shall establish relevant system logging policies such as required audit log content, log and event time synchronization, and log file retention periods. The LI shall establish procedures for securely handling, collecting, and preserving digital evidence while ensuring its authenticity and integrity so that forensic investigations can be conducted after the event or after critical operations resume. The LI shall closely integrate plans for forensic readiness with plans for incident management and other related business planning activities. The LI shall train its staff so that all those involved in a particular incident understand their responsibilities related to handling digital evidence, ensuring it is not compromised and valid as per the local jurisdiction.

VII. Testing Program

7.1 Comprehensive Testing Program As part of its cyber resilience framework, the LI shall establish and maintain a comprehensive testing program. The testing program shall be developed using a risk-based approach and include a wide range of methodologies, practices, and tools for monitoring, assessing, and evaluating the effectiveness of the cyber resilience framework's core components. The testing program shall be reviewed and updated on a regular basis, taking into account the evolving threat landscape and the criticality of information assets.

7.2 Internal Stakeholder Involvement and Ecosystem Collaboration When implementing its testing program, the LI shall develop appropriate capabilities and involve all relevant internal stakeholders including business lines and operational teams. To improve its cyber resilience stance, the LI shall also collaborate with entities in its ecosystem. The LI shall involve its board and senior management appropriately such as members of crisis management teams and inform them of test results.

7.3 Continuous Improvement from Testing Results To continuously improve its cyber resilience stance, the LI shall establish policies and procedures to prioritize and resolve issues identified during the various tests, as well as perform subsequent validation to determine whether gaps have been addressed sufficiently. The LI shall ensure that the tests are carried out by independent parties whether internal or external.

7.4 Range of Testing Methodologies and Tools The LI shall use a wide range of testing methodologies, practices, and tools such as vulnerability assessments, scenario-based testing, penetration tests, and red team tests which may overlap partly or be combined.

7.5 Vulnerability Assessment and Management Process The LI shall develop and regularly update a vulnerability management process to classify, prioritize, and resolve potential vulnerabilities identified in vulnerability assessments, as well as perform subsequent validation to determine whether gaps have been addressed sufficiently. The vulnerability management process shall help identify exploitable weaknesses in critical systems and technologies as well as conditions that allow for human error and accidents in critical functions. The LI shall conduct vulnerability

scanning of its external-facing services as well as internal systems and networks on a regular basis. These scans shall rotate between environments to ensure they reach all environments throughout the year.

7.6 Pre-Deployment and Ongoing Vulnerability Assessments The LI shall conduct vulnerability assessments to identify bugs and weaknesses before deploying or redeploying new or existing services supporting critical functions, applications, and infrastructure components with change and release management processes in place. The LI shall conduct vulnerability assessments on running services, applications, and infrastructure components on a regular basis, monitoring and evaluating the effectiveness of security controls to address identified vulnerabilities and checking for compliance with regulations, policies, and configurations.

7.7 Vulnerability Management Practices As part of its vulnerability management process, the LI shall develop and implement a variety of effective practices and tools such as a bug bounty program or static and dynamic code reviews, as well as appropriate safeguards to manage them.

7.8 Scenario-Based Testing for Incident Response To evaluate and improve its incident detection capability as well as response, resumption, and recovery plans, the LI shall conduct various scenario-based tests including extreme but plausible scenarios. The LI shall design tests that: address a sufficiently broad range of scenarios such as simulation of extreme but plausible cyber-attacks; are intended to challenge the assumptions of response, resumption, and recovery practices including governance arrangements and communication plans; include data destruction, data integrity corruption, data loss, and system and data availability; cover breaches affecting multiple components of the LI's ecosystem to identify and analyze potential complexities, interdependencies, and potential contagion at the business and operational levels.

7.9 Cyber Threat Intelligence in Testing The LI shall use cyber threat intelligence (CTI) and cyber threat modelling to imitate the unique characteristics of cyber threats to the extent possible. The LI shall conduct exercises to test processes and staff's ability to respond to unfamiliar scenarios. The LI shall collaborate with the ecosystem to develop cybersecurity incident scenarios involving significant financial loss and use them for stress tests to understand potential spillovers and contagion risk to the ecosystem.

7.10 Board and Senior Management Participation When appropriate, the LI's board of directors and senior management shall be involved in scenario-based testing.

7.11 Penetration Testing Penetration tests shall be performed by the LI to identify vulnerabilities that may affect its systems, networks, applications, people, or processes. These tests shall simulate actual attacks on the LI's systems to provide an in-depth evaluation of their security. Penetration tests shall be conducted regularly and whenever there are major updates to or deployment of systems. The LI shall include all critical internal and external stakeholders in penetration testing exercises as appropriate.

7.12 Integration with Enterprise Risk Management and SDLC The LI shall incorporate testing practices into its enterprise risk management process in order to identify, analyze, and fix cybersecurity vulnerabilities caused by new products, services, or interconnections. The LI shall perform security assessments and tests at all stages of the system development life cycle and at any level including business, application, and technology for the entire application portfolio including mobile applications.

7.13 Automated Tools for Fixing Weaknesses The LI shall implement best practices and automated tools to support processes and procedures for fixing technical and organizational weaknesses identified during testing exercises and ensuring compliance with approved policies and configurations.

7.14 Red Team Testing The LI shall use red teams to introduce an adversary perspective in a controlled setting to challenge its own organization and ecosystem. Red teams test potential vulnerabilities as well as the effectiveness of an LI's mitigating controls including people, processes, and technology. A red team can be made up of LI employees as well as outside experts who are independent of the function being tested. The red team shall conduct regular exercises and collaborate with its cyber defense team such as a blue team to share findings and improve the LI's cyber resilience stance.

7.15 CTI-Informed Red Team Exercises The LI shall use appropriate cyber threat intelligence (CTI) to inform its testing methods such as by designing tests to simulate advanced threat agent capabilities and extreme but plausible scenarios. The LI shall conduct red team exercises based on specific and plausible threat scenarios using reliable and valuable CTI.

7.16 Industry-Wide and Ecosystem Testing Exercises The LI shall proactively engage in industry-wide exercises in order to test cooperation and coordination protocols and communication plans. These exercises shall foster the LI's awareness on cross-sector cooperation and third-party risks. The LI shall promote, organize, and manage exercises designed to test its response, resumption, and recovery plans and processes including LI participants, critical service providers, and linked FMIs as appropriate. The LI shall take part in industry-wide tests and exercises organized by relevant authorities. Testing shall include scenarios that cover breaches affecting multiple components of the LI's ecosystem.

VIII. Situational Awareness and Cyber Threat Intelligence

8.1 Cyber Threat Identification and Analysis The LI shall identify cyber threats that could materially affect its ability to operate or provide services as expected, or that may have a significant impact on its ability to meet its own obligations or have knock-on effects within its own ecosystem. The LI shall include in its threat analysis those threats that could cause extreme but plausible cyber events even if they are thought unlikely to happen or have never happened before. This analysis shall be regularly reviewed and updated.

8.2 Cyber Threat Intelligence (CTI) Gathering and Analysis The LI shall: create a process for gathering and analyzing relevant cyber threat information including internal and external business and system information to provide a business-specific context and turn information into usable CTI; have the ability to analyze collected data and assess the potential impact on its cyber resilience framework; gather and analyze cyber threat information and produce cyber threat intelligence that is reviewed and updated regularly; use multiple sources of intelligence from internal and external sources such as application, system, and network logs, security products like firewalls and intrusion detection systems, trusted threat intelligence providers, and publicly available information, correlated log analyses, alerts, traffic flows, cyber events in other sectors, and geopolitical events.

8.3 Threat Intelligence Subscriptions and Information Sharing Center To acquire threat information, the LI shall belong or subscribe to a threat and vulnerability information-sharing source and information-sharing and analysis center that provides information on cyber threats and vulnerabilities where available. The LI's cyber threat information shall include analysis of real-world attackers' tactics, techniques, and procedures, as well as information on geopolitical developments that may trigger cyber-attacks on any entity within the LI's ecosystem.

8.4 Threat Intelligence Application for Risk Management The LI shall use the threat information collected from different sources while considering its own business and technical characteristics to: determine threat actors' motivations and capabilities including their tactics, techniques, and procedures, as well as the extent to which the LI is vulnerable to a targeted attack; reassess the risk of technical vulnerabilities in operating systems, applications, and other software that could be exploited to launch attacks; and analyze cybersecurity incidents experienced by other organizations including types of incidents, origin of attacks, targets of attacks, preceding threat events, and frequency.

8.5 Continuous CTI Integration with Operations The LI shall continuously use the CTI it has developed to assess and manage security threats and vulnerabilities in order to implement threat-informed cybersecurity controls in its systems and to continuously improve its cyber resilience framework and capabilities. The LI shall: ensure that CTI is available to appropriate LI staff responsible for mitigating cyber risks at strategic, tactical, and operational levels; integrate and align its CTI process with that of its SOC, using information from its SOC to improve its CTI and using its CTI to inform its SOC; and use CTI to help inform and update its testing program to ensure it is up-to-date with the latest threat landscape.

8.6 Information Sharing Objectives, Scope, and Rules The LI shall define: its information-sharing objectives in line with its business objectives and cyber resilience framework; and the scope of information-sharing activities including the types of information available to be exchanged, the circumstances under which sharing is permitted, and those with whom the information can and should be shared. The LI shall establish and review its information-sharing rules and agreements on a regular basis and implement procedures that allow information to be shared promptly and in accordance with the objectives and scope defined in the information-sharing rules and agreements. The LI shall establish and implement protocols with employees for sharing information relating to threats, vulnerabilities, and cyber incidents, based on their specific roles and responsibilities.

8.7 Active Participation in Information-Sharing Groups The LI shall participate actively in existing information-sharing groups and facilities including cross-industry, cross-government, and cross-border groups to gather, distribute, and assess information about cyber practices, cyber threats, and early warning indicators related to cyber threats. The LI shall consider exchanging information on its cyber resilience framework with trusted stakeholders as needed to promote understanding of each other's approach to securing systems that are linked or interfaced. The LI shall participate in efforts to identify and address gaps in current information-sharing mechanisms to facilitate an ecosystem-wide response to large-scale incidents.

8.8 Incident Information Sharing Through Trusted Channels In the event of an incident, the LI shall plan for information-sharing through trusted channels, collecting and exchanging timely information that could facilitate the detection, response, resumption, and recovery of its own systems and those of other entities within the LI's ecosystem during and after a cyber-attack.

IX. Learning and Evolution - Continuous Improvement

9.1 Lessons Learned from Real-Life Cyber Incidents To enhance its cyber resilience capabilities, the LI shall identify and categorize lessons learned (strategic, tactical, and operational) from real-life cyber incidents both internal and external to the LI. To improve its risk mitigation capabilities as well as its cyber response, resumption, recovery, and contingency plans, the LI shall incorporate these key lessons learned from real-life cyber incidents and results of testing on the LI and other organizations.

9.2 Cybersecurity Awareness Materials and Staff Training When highly visible cyber events or regulatory alerts occur, the LI shall ensure that cybersecurity awareness materials are made available to staff. The LI shall incorporate lessons learned into staff training, awareness programs, and materials on an ongoing and dynamic basis and validate their effectiveness. The LI shall utilize industry and authority initiatives related to awareness and training where possible.

9.3 Continuous Cyber Resilience Training Program The LI shall have a program for continuous cyber resilience training. This training program shall be conducted to board members and senior management at least once a year covering incident response, current cyber threats, and emerging issues such as spear phishing.

9.4 Proactive and Predictive Cyber Risk Management The LI's cyber risk management practices shall include proactive protection against future cyber events in addition to reactive controls. The LI shall strive for predictive capabilities by collecting data from multiple internal and external sources, defining a baseline for behavioral and system activity, and analyzing activities that deviate from the baseline.

9.5 Metrics, Maturity Models, and Benchmarking Metrics and maturity models enable the LI to assess its cyber resilience maturity in relation to a set of predefined criteria typically its operational reliability objectives. The LI must analyze and correlate findings from audits, vulnerability assessments, management information, incidents, near misses, tests, and exercises with external and internal intelligence for this benchmarking. Metrics can assist the LI in identifying gaps in its cyber resilience framework for remediation as well as allowing the LI to systematically evolve and achieve more mature states of cyber resilience.

9.6 Testing Program Performance Metrics To assess the performance and effectiveness of its testing program, the LI shall develop, monitor, and analyze metrics. The LI shall use the results of the analysis to improve its testing program.

9.7 Cyber Resilience Strategy and Framework Indicators The LI shall create a set of indicators and management information to measure and monitor the effectiveness of the cyber resilience strategy and framework as well as its evolution over time. Relevant information and indicators could include for example key risk indicators (KRIs), key performance indicators (KPIs), maturity model assessments, audit findings, vulnerability assessment results, incident statistics, and benchmarking results.